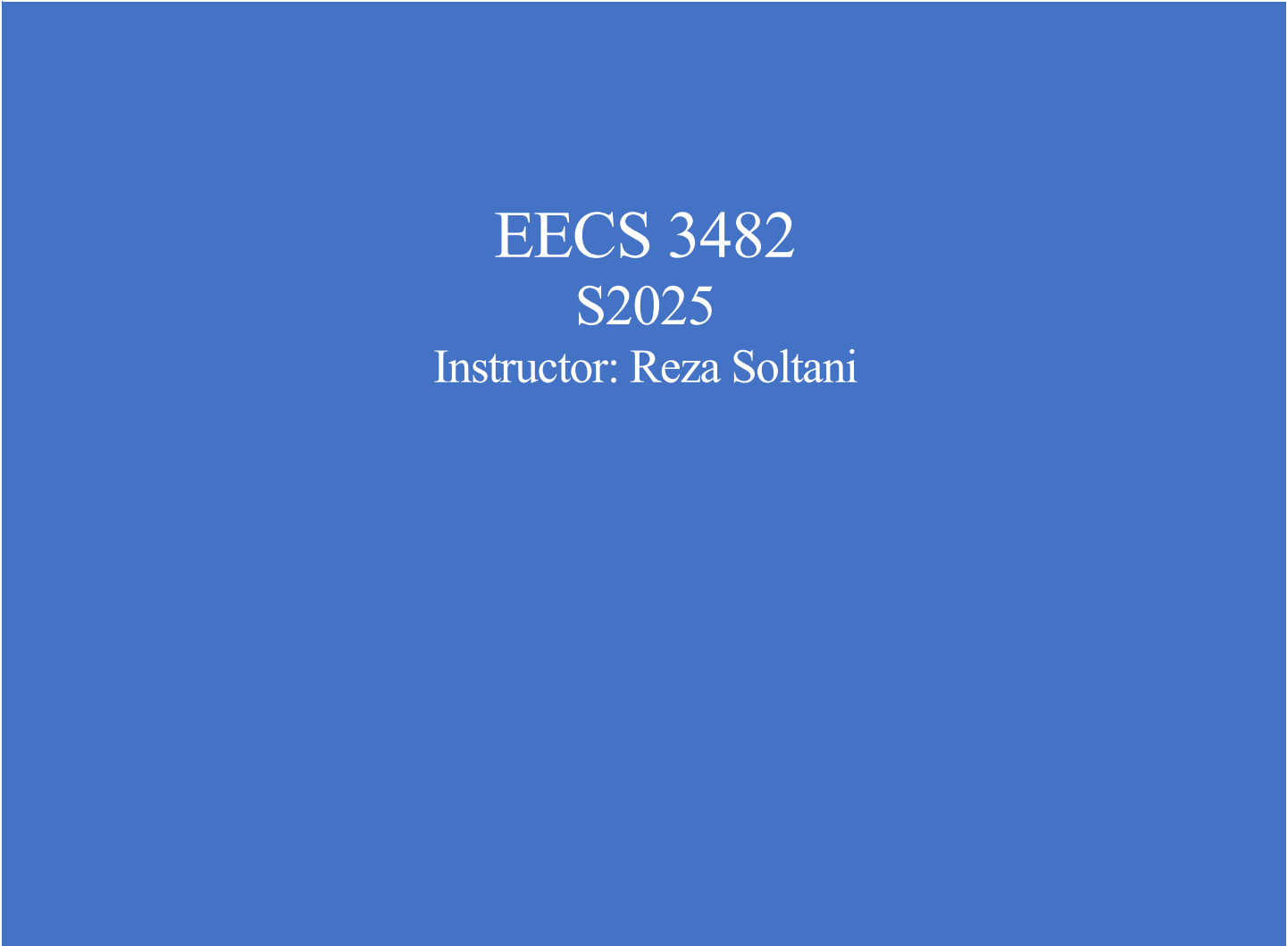




Lab 3 – Password Security



EECS 3482
S2025
Instructor: Reza Soltani

Lab Objectives

By the end of this lab, you will:

- Understand brute-force and dictionary-based password attacks
- Gain familiarity with various security tools, including John the Ripper and Hydra
- Learn the basics of Unix password files
- Understand the basics of SSH

Lab Requirements

- **Tools/Environments:** Azure Lab (Optional)
 - Kali Linux
 - SSH Server
 - John the Ripper
 - Hydra
- **Prerequisites:**
 - Basic knowledge of Linux command-line interface (CLI).
 - Familiarity with cryptographic terminology.
 - An SSH server as target

Lab Format

For every step of your labs, including this lab and all future labs in the course, you must provide a clear and **legible screenshot** whenever you use the command prompt.

Before taking the screenshot, and either before or after completing the step, you **must** enter the following command so that your **username**, **full name**, and **timestamp** are visible in the screenshot:

```
echo " Step completed by $(whoami), name: <first> <last>, on $(date)"
```

Note, replace *<first>* and *<last>* with your own first name and last name before running the command.

For example, a student with the name *John Smith* and username *JSUser1* should run the following command:

```
echo "Step completed by $(whoami), name: john smith, on $(date)"
```

to get the following result:

```
Step completed by JSUser1, name: John Smith, on Sat 17 May 2025 12:48:05 EDT
```

Note, there are different kinds of shell interface within Unix/Linux systems. Depending on the environment you are in (such as the *eeecsvm*'s kali environment which uses **ksh** instead of **bash** shell), you may have to enter the following modified command:

```
echo " Step completed by `whoami`, name: <first> <last>, on `date`"
```

or alternatively, enter **bash** in the command prompt to switch to *bash* shell before entering the original *echo* command.

Also note: If you are working on a Windows machine, you must use an equivalent command such as:

```
echo Step completed by %USERNAME%, name: <first> <last>, on %DATE% %TIME%
```

If a lab step does not include the above command or a clear screenshot, marks will be deducted.

Part 1 – John the Ripper

John the Ripper is a popular open-source password cracking tool used by security professionals to test password strength by attempting to recover plaintext passwords from hashed values using techniques like dictionary attacks, and brute force.

In the first part we'll use John the Ripper (JtR) to crack the password assigned to a Linux user.

To complete this part, follow these steps and document your result:

1. Open Kali, or download JtR from <https://www.openwall.com/john/>
 - a. If trying to install a new version of JtR on Kali or other Linux distributions see the **Notes section** at the bottom of the lab.
2. Create a new working folder for your lab (ex. Somewhere in your home directory)
3. Create a new Unix user using 'useradd' and 'passwd' commands (use sudo if needed):
 - a. Enter '**useradd test**'
 - b. Enter '**passwd test**' and then enter **test** when prompted for password
4. In newer UNIX-based distros, a list of users (usernames) along with other information is stored in the /etc/passwd file, whereas the password hashes corresponding to each user account are stored in a separate /etc/shadow file(s). We can extra the content using the following command:

sudo grep test /etc/shadow > hash.txt

5. Display the content of the **hash.txt** using the **cat** command. Describe the components of the outputted line. Note, each component is separated by a colon symbol.

Note: If at any step an operation fails due to permission, include 'sudo'.

6. Start JtR and pass **hash.txt** as input:

john hash.txt

7. Allow JtR to crack the password.
8. Document every step of your work including any error you may get at this step.

9. Run the same command with a new argument:

```
john --format=crypt hash.txt
```

and then run:

```
john --format=crypt hash.txt --show
```

Document your result and explain why your result is different from the previous attempt in step 6.

Before proceeding with the next steps, you should remove the *.john* folder created by the previous commands. If the *.john* folder is not removed, then the next two steps will not execute correctly.

On Kali you will find the *.john* folder under: */home/<your-username>/john/*

10. Modify JtR to use a **specific dictionary file** as input to perform the attack on the same input file. On Kali there are many wordlists. Some are usually stored at */usr/share/wordlists*. Note, some of the wordlist files are stored as compressed (.gz) files and need to be uncompressed first.

Update the password list file if necessary so that it includes that password that you used in step 3, although the password chosen in step 3 is most likely in your dictionary files already.

Document where you found the dictionary file, the command you entered, and the results you obtain from JtR.

11. Modify your JtR command to use a **minimum of 4 and maximum of 6 characters** while performing the dictionary attack. Document your command and your result.

Supporting links:

<https://www.openwall.com/john/doc/EXAMPLES.shtml> and
<https://www.openwall.com/john/doc/CONFIG.shtml>

Part 2 - Hydra

Hydra is a fast and flexible password-cracking tool used to perform brute-force attack dictionary attack against login services like SSH, FTP, HTTP, and more. It automates the process of trying many username and password combinations to find valid credentials. Commonly used in penetration testing, Hydra helps identify weak authentication setups.

See: <https://www.kali.org/tools/hydra/>

In this part, you are going to use **Hydra** to crack an SSH account. This can be implemented on the cloud based lab environment, EECSVM environment, or on your local machine.

To execute this attack you will need a working environment with Hydra installed, and a target SSH server that you are allowed to attack. You can set up an SSH server on your local Linux environment, on Kali VM, or on the Metasploitable3 VM.

- 1- Identify the IP address of the target SSH server. You can get the correct IP by logging into the target machine and running the command similar to the below:

```
Ifconfig | grep -A 8 eth0
```

Note: replace *eth0* with the name of the NIC assigned to your environment

- 2- From the target server, you can try any of the following commands to verify the status of the SSH server:
 - i. `sudo service ssh status`
 - ii. `sudo netstat -tuln | grep :22`
 - iii. `sudo systemctl status ssh`

If there are no SSH server running on the target machine, then you first have to setup and/or start the SSH server first. Follow the link at the bottom of this lab for steps to install an SSH server. If the SSH server is already installed, then you may have to just start it. A command similar to the one below, can start your SSH server:

```
sudo systemctl start ssh
```

- 3- From the working server (e.g., Kali), verify that you can access the SSH server. Assuming the IP of the SSH server is 192.168.0.102, and the username is *vagrant*, then you can try to SSH into the server by using the following command:

```
ssh vagrant@192.168.0.102
```

- 4- If using Kali on EECSVM, there is already an instance of Hydra installed, and accessible from the menu. However if you decide to install it again follow the steps under the **Notes** section.
- 5- Run Hydra on Kali by entering the following command, while replacing [TARGET] with the target machine running the SSH server. Replace the arguments: *vagrant* and *admin* with the username and password that are assigned to the target machine.

Note, those credentials must already be setup on the target machine, otherwise *Hydra* will fail to crack the password.

```
hydra -l vagrant -p admin [TARGET] -t 4 ssh
```

- 6- Document your results and clearly explain all arguments passed to Hydra.
- 7- Try Hydra with a wordlist called password.lst. Update the username accordingly based on the credentials assigned to the target machine:

```
hydra -l vagrant -P password.lst [TARGET] -t 4 ssh
```

Note, the file **password.lst** should exist in your **working directory**. The password.lst file **should contain** the SSH password you have assigned to your target. If using Metasploitable3 as your target, then '**vagrant**' is the username and the password. You can obtain the wordlist file from Kali or online sources.

- 8- Document the size of your password.lst file in terms of entries it has, and the result of your attack including the amount of time it took to crack the password.
- 9- In a few sentences, describe the differences between Hydra and JdR in terms of features and performance.

Part 3 – Research and Exploration

- 1- Aside from JtR and Hydra, name one more tool related to brute force attacks and password cracking. Describe its main difference compared to JtR and Hydra.

Lab Submission

Students will submit the following:

1. A PDF describing the steps completed for part 1, 2 and 3 with adequate description to show that you've completed every step. Include clear screenshots of commands, show inputs and outputs from the programs (John and Hydra). Organize your PDF based on the parts and steps stated in the lab.
2. Submit your files through eClass before the deadline!

Notes

This section is for your information only. It explains how to prepare and install SSH, Hydra and John the Ripper on Kali and other Linux Distributions.

SSH Server

See: <https://www.cherryservers.com/blog/how-to-enable-and-secure-ssh-on-ubuntu-quick-and-easy-steps>

Hydra

Follow the steps below to configure the nameservers and download Hydra to your Kali environment (If not available already) .

Step 1: Update name servers by editing resolv.conf:

sudo nano /etc/resolv.conf

Step 2: Enter the following line in resolv.conf and save:

nameserver 8.8.8.8

Step 3: Update your apt-get repositories:

sudo apt-get upgrade

Step 4: Download Hydra using Apt-get:

sudo apt-get install hydra

Select Yes(Y) if you are asked about a question during upgrade or installation phase.

John the Ripper

After updating the networking changes described in the section above (Steps 1 to 3), try:

sudo apt-get install john